

Chapter 2 — Malware

ในโลกดิจิทัลปัจจุบัน ระบบคอมพิวเตอร์และเครือข่ายกลายเป็นโครงสร้างพื้นฐานสำคัญของชีวิตประจำวัน ทั้งในระดับบุคคล องค์กร และประเทศ แต่ในขณะเดียวกันก็เกิด “ภัยคุกคามทางไซเบอร์” ที่มุ่งโจมตีระบบเหล่านี้ หนึ่งในภัยที่พบบ่อยและมีผลกระทบกว้างขวางที่สุดคือ “มัลแวร์” (Malware)

มัลแวร์ไม่ได้เป็นเพียงซอฟต์แวร์ที่สร้างความเสียหายเท่านั้น แต่ยังเป็นเครื่องมือทางยุทธศาสตร์ที่ผู้ไม่หวังดีใช้เพื่อเจาะระบบ ขโมยข้อมูล หรือแทรกแซงการทำงานของระบบสารสนเทศในรูปแบบต่าง ๆ

2.1 ความหมายของ Malware

คำว่า **Malware** ย่อมาจาก **Malicious Software** หมายถึง “โปรแกรมหรือซอฟต์แวร์ที่ถูกออกแบบมาเพื่อทำลาย ขัดขวาง หรือเข้าถึงระบบคอมพิวเตอร์โดยไม่ได้รับอนุญาต”

มัลแวร์สามารถแฝงตัวได้ในหลายรูปแบบ เช่น ไวรัส (Virus), เวิร์ม (Worm), โทรจัน (Trojan), สปายแวร์ (Spyware), แรนซัมแวร์ (Ransomware) หรือแม้กระทั่งมัลแวร์ที่ไม่มีไฟล์ (Fileless Malware) ซึ่งทำงานอยู่ในหน่วยความจำของระบบโดยไม่ทิ้งร่องรอยบนดิสก์

คุณสมบัติทั่วไปของมัลแวร์:

- ทำงานโดยไม่ได้รับอนุญาตจากเจ้าของระบบ
- มีวัตถุประสงค์แฝง เช่น ขโมยข้อมูล ทำลายระบบ หรือสร้างรายได้ให้ผู้โจมตี
- สามารถแพร่กระจายผ่านเครือข่าย อินเทอร์เน็ต หรืออุปกรณ์จัดเก็บข้อมูลพกพา
- มักใช้ช่องโหว่ (Vulnerability) ของซอฟต์แวร์หรือความประมาทของผู้ใช้เป็นช่องทางโจมตี

2.1.1 วัตถุประสงค์ของมัลแวร์

มัลแวร์ถูกพัฒนาเพื่อตอบสนองต่อเป้าหมายเฉพาะของผู้สร้าง ซึ่งอาจมีลักษณะทางเทคนิคหรือเชิงกลยุทธ์ จุดประสงค์หลักมีดังนี้:

1. การขโมยข้อมูล (Data Theft)

เพื่อดึงข้อมูลสำคัญ เช่น รหัสผ่าน หมายเลขบัตรเครดิต หรือข้อมูลส่วนบุคคลไปในทางทุจริต

ตัวอย่าง: มัลแวร์ประเภท Keylogger หรือ Spyware ที่บันทึกการพิมพ์ของผู้ใช้

2. การควบคุมระบบจากระยะไกล (Remote Control)

ผู้โจมตีอาจต้องการเข้าถึงเครื่องของเหยื่อเพื่อใช้เป็นฐานในการโจมตีระบบอื่น

ตัวอย่าง: Remote Access Trojan (RAT) ที่เปิดช่องหลังบ้านให้ผู้ไม่หวังดี

3. การทำลายหรือขัดขวางการทำงาน (Disruption / Destruction)

มัลแวร์บางชนิดออกแบบมาเพื่อทำให้ระบบไม่สามารถทำงานได้ เช่น การลบไฟล์

หรือทำให้ระบบล่ม

ตัวอย่าง: Wiper malware เช่น NotPetya

4. การเรียกค่าไถ่ (Ransom)

เข้ารหัสข้อมูลของผู้ใช้แล้วเรียกร้องให้จ่ายเงินเพื่อแลกกับการปลดล็อก

ตัวอย่าง: Ransomware เช่น WannaCry, LockBit

5. การโฆษณาหรือสร้างรายได้แบบแฝง (Ad Fraud / Cryptomining)

ใช้ทรัพยากรของเหยื่อในการขุดเหรียญดิจิทัล (Crypto Mining) หรือเปิดโฆษณาโดยไม่ได้รับอนุญาต

2.1.2 แรงจูงใจของผู้สร้างมัลแวร์

แรงจูงใจในการสร้างและแพร่กระจายมัลแวร์สามารถแบ่งได้หลายประเภท ดังนี้:

ประเภทแรงจูงใจ	รายละเอียด	ตัวอย่างสถานการณ์
1. การเงิน (Financial Gain)	ผู้โจมตีมุ่งหวังผลประโยชน์ทางเศรษฐกิจ เช่น ขโมยข้อมูลบัตรเครดิต หรือเรียกค่าไถ่ข้อมูล	Ransomware, Banking Trojan
2. การจารกรรมข้อมูล (Espionage)	รัฐหรือองค์กรใช้มัลแวร์เพื่อสอดแนมข้อมูลคู่แข่ง เช่น ความลับทางการค้า หรือข้อมูลทางทหาร	Stuxnet, Flame
3. การก่อวินาศกรรม (Sabotage)	มัลแวร์ถูกใช้เพื่อทำลายระบบหรือสร้างความเสียหายต่อโครงสร้างพื้นฐาน	NotPetya, Shamoon
4. การเผยแพร่แนวคิดทางการเมืองหรือสังคม (Hacktivism)	กลุ่มแฮกเกอร์ใช้มัลแวร์เพื่อประท้วงหรือสร้างแรงกดดันต่อองค์กร	Anonymous, LulzSec
5. ความท้าทายส่วนตัวหรือการทดลอง (Curiosity / Fame)	ผู้พัฒนามัลแวร์บางรายต้องการแสดงความสามารถหรือทดสอบเทคโนโลยี	สร้างไวรัสต้นแบบเพื่อศึกษาผลกระทบ

แรงจูงใจเหล่านี้ทำให้มัลแวร์ไม่ใช่เพียงภัยด้านเทคนิค แต่ยังเชื่อมโยงกับเศรษฐกิจ สังคม และการเมืองในระดับโลก

ตัวอย่างสถานการณ์จริง

- **WannaCry (2017):** แรนซัมแวร์ที่แพร่กระจายอย่างรวดเร็วทั่วโลก โดยใช้ช่องโหว่ SMB ของ Windows ส่งผลกระทบต่อองค์กรกว่า 150 ประเทศ
- **Stuxnet (2010):** มัลแวร์ที่ออกแบบมาเพื่อโจมตีระบบควบคุมโรงงานอุตสาหกรรม (SCADA) ของอิหร่าน ถือเป็นกรณีแรกของ “cyber weapon” ที่มีเป้าหมายทางภูมิรัฐศาสตร์
- **Emotet (2014–2021):** มัลแวร์ที่เริ่มต้นจาก Banking Trojan และพัฒนาเป็นโครงสร้างบอทเน็ตขนาดใหญ่ ใช้แพร่กระจายมัลแวร์อื่นต่อเนื่อง

2.1.3 สรุปแนวคิดสำคัญ

มัลแวร์ (Malware) เป็นซอฟต์แวร์ที่ออกแบบมาเพื่อสร้างผลกระทบเชิงลบต่อระบบสารสนเทศ ไม่ว่าจะเป็นการขโมยข้อมูล การทำลายระบบ หรือการหาผลประโยชน์ทางการเงิน การทำความเข้าใจกลไกและแรงจูงใจของผู้สร้างมัลแวร์ช่วยให้นักศึกษาสามารถวิเคราะห์และออกแบบมาตรการป้องกันที่เหมาะสมได้

ในมุมมองด้านความมั่นคงปลอดภัย การป้องกันมัลแวร์ไม่ได้อาศัยเพียงซอฟต์แวร์ป้องกันไวรัสเท่านั้น แต่ต้องอาศัยแนวคิดแบบ “Defense in Depth” ที่รวมถึงการอบรมผู้ใช้ การบริหารสิทธิ์การเข้าถึง และการตรวจสอบระบบอย่างต่อเนื่อง

💡 Key Takeaway:

Malware คือภัยคุกคามที่มีทั้งมิติทางเทคนิค เศรษฐกิจ และยุทธศาสตร์ ความเข้าใจอย่างลึกซึ้งต่อแรงจูงใจของผู้สร้างมัลแวร์คือกุญแจสำคัญในการป้องกันและตอบสนองต่อภัยไซเบอร์ในยุคดิจิทัล.

2.2 Taxonomy: Major Malware Types

มัลแวร์ (Malware) มีหลายรูปแบบและวิวัฒนาการอย่างต่อเนื่องตามเทคโนโลยีและพฤติกรรมของผู้ใช้ การจำแนกประเภทของมัลแวร์จึงเป็นสิ่งสำคัญสำหรับผู้เชี่ยวชาญด้านความปลอดภัย เพื่อให้เข้าใจ ลักษณะ กลไกการแพร่กระจาย และผลกระทบของมัลแวร์แต่ละประเภท

ในหัวข้อนี้ เราจะศึกษาประเภทหลักของมัลแวร์ที่พบบ่อย 9 ประเภท พร้อมตัวอย่างและแนวทางป้องกันในเบื้องต้น

2.2.1 Virus (ไวรัสคอมพิวเตอร์)

ไวรัสคอมพิวเตอร์ (Computer Virus) ถือเป็นมัลแวร์ชนิดแรก ๆ ที่ถูกสร้างขึ้นและกลาย เป็นจุดเริ่มต้นของภัยคุกคามทางไซเบอร์ในยุคดิจิทัล ไวรัสมีลักษณะเฉพาะคือสามารถ “แนบตัวเอง” (Attach) เข้ากับไฟล์ โปรแกรม หรือเอกสารที่สามารถเรียกใช้งานได้ เช่น ไฟล์ระบบปฏิบัติการหรือเอกสาร Office โดยจะเริ่มทำงานทันทีเมื่อไฟล์นั้นถูกเปิดหรือเรียกใช้งาน เมื่อไวรัสเข้าสู่ระบบแล้ว มันจะคัดลอกตัวเองและแพร่กระจายต่อไปยังเครื่องอื่นผ่านสื่อเก็บข้อมูลแบบพกพา อีเมล หรือเครือข่าย ทำให้การติดเชื้อสามารถขยายตัวได้อย่างรวดเร็ว

ในแง่ของ กลไกการทำงาน, ไวรัสจะเริ่มจากการเข้าสู่ระบบผ่านไฟล์หรือสื่อจัดเก็บข้อมูล เช่น แฟลชไดรฟ์หรือดิสก์ จากนั้นจะฝังตัวใน โปรแกรมหรือเอกสารเพื่อรอให้ผู้ใช้เปิดใช้งาน เมื่อไฟล์ถูกเปิด ไวรัสจะถูกเรียกใช้โดยอัตโนมัติและเริ่มทำสำเนาตัวเอง (Replication) เพื่อแพร่ต่อไปยังไฟล์หรือระบบอื่น ๆ ซึ่งอาจทำให้ไฟล์ข้อมูลเสียหาย ระบบทำงานผิดพลาด หรือถึงขั้นหยุดทำงานได้

ไวรัสมีหลายประเภทตามกลไกการติดเชื้อ เช่น

- **Boot Sector Virus** ที่ฝังตัวอยู่ในพื้นที่บูตของดิสก์และทำงานตั้งแต่เครื่องเริ่มเปิด
- **Macro Virus** ซึ่งแฝงในเอกสาร Microsoft Office โดยใช้สคริปต์มาโคร (VBA) เพื่อรันคำสั่งอัตโนมัติ
- **Polymorphic Virus** ซึ่งสามารถเปลี่ยนรูปแบบของโค้ดตัวเองทุกครั้งที่แพร่กระจาย เพื่อหลบเลี่ยงการตรวจจับของ โปรแกรมป้องกันไวรัส

ในอดีตมีเหตุการณ์แพร่ระบาดของไวรัสชื่อดังที่สร้างความเสียหายเป็นวงกว้าง เช่น **ILOVEYOU Virus (ปี 2000)** ซึ่งแพร่กระจายผ่านอีเมลหัวข้อ “ILOVEYOU” และเมื่อเปิดไฟล์แนบจะลบไฟล์ระบบและส่งตัวเองต่อไปยังผู้ติดต่อทั้งหมดในสมุดรายชื่อ อีกตัวอย่างคือ **Melissa Virus (ปี 1999)** ซึ่งฝังตัวในไฟล์ Word และแพร่กระจายผ่าน Outlook โดยอัตโนมัติ

แนวทางป้องกันไวรัส เริ่มจากการใช้โปรแกรมป้องกันไวรัส (Antivirus) ที่มีการอัปเดตฐานข้อมูลลายเซ็น (Signature) อย่างสม่ำเสมอ เพื่อตรวจจับไวรัสชนิดใหม่ ๆ รวมถึงการหลีกเลี่ยงการเปิดไฟล์แนบ อีเมล หรือ โปรแกรมจากแหล่งที่ไม่น่าเชื่อถือ และการสำรองข้อมูล (Backup) เป็นประจำเพื่อป้องกันความเสียหายหากเกิดการติดเชื่อ นอกจากนี้ การให้ความรู้แก่ผู้ใช้เกี่ยวกับพฤติกรรมเสี่ยง เช่น การดาวน์โหลดไฟล์จากเว็บไซต์ที่ไม่น่าเชื่อถือ ยังเป็นมาตรการสำคัญในการลดโอกาสการติดไวรัสได้อย่างมีประสิทธิภาพ

💡 **สรุป:** ไวรัสมัลแวร์คือมัลแวร์ที่อาศัยผู้ใช้ในการแพร่กระจาย มักแฝงอยู่ในไฟล์ที่ดูปลอดภัยและเริ่มทำงานเมื่อถูกเปิดใช้งาน การเข้าใจรูปแบบการทำงานของไวรัสช่วยให้สามารถวางมาตรการป้องกันได้อย่างรัดกุม ทั้งด้านเทคนิคและพฤติกรรมของผู้ใช้.

2.2.2 Worm (เวิร์ม)

เวิร์ม (Worm) เป็นมัลแวร์ประเภทหนึ่งที่มีความสามารถในการ **แพร่กระจายตัวเองได้โดยอัตโนมัติ โดยไม่ต้องอาศัยการกระทำของผู้ใช้** ซึ่งแตกต่างจากไวรัสที่ต้องแนบตัวกับไฟล์หรือโปรแกรมก่อนจึงจะแพร่กระจายได้ เวิร์มมักอาศัยช่องโหว่ (Vulnerability) ของระบบปฏิบัติการ เครือข่าย หรือ โพรโตคอลสื่อสาร เช่น SMB, RDP, หรืออีเมล เพื่อคัดลอกตัวเองไปยังเครื่องอื่นอย่างต่อเนื่องในลักษณะของการ “แพร่เชื้อลูกโซ่” (Chain Infection) ทำให้การแพร่กระจายสามารถเกิดขึ้นได้รวดเร็วและในวงกว้างภายในเวลาไม่กี่ชั่วโมง

ในเชิงเทคนิค กลไกการทำงานของเวิร์ม มักเริ่มต้นจากการสแกนหาอุปกรณ์ในเครือข่ายที่มีช่องโหว่เปิดอยู่ เช่น พอร์ต 445 (SMB) หรือพอร์ต 3389 (RDP) เมื่อพบเป้าหมายที่มีช่องโหว่ เวิร์มจะส่งสำเนาของตนเองเข้าไปติดตั้งบนเครื่องนั้น และเริ่มกระบวนการแพร่กระจายต่อไปยังเครื่องอื่นโดยอัตโนมัติ วัฏจักรนี้ทำให้จำนวนเครื่องที่ติดเชื่อเพิ่มขึ้นแบบทวีคูณโดยไม่ต้องพึ่งผู้ใช้ใด ๆ

ผลกระทบของเวิร์ม มีตั้งแต่การทำให้ระบบเครือข่ายล่มจากการใช้แบนด์วิดท์อย่างหนัก ไปจนถึงการทำหน้าที่เป็นพาหะนำ Payload อื่น ๆ เข้ามาในระบบ เช่น การดาวน์โหลดแรนซัมแวร์ (Ransomware) โทรจัน (Trojan) หรือ Backdoor เพื่อเปิดช่องทางให้ผู้โจมตีเข้าควบคุมเครื่องของเหยื่อได้ในภายหลัง นอกจากนี้ เวิร์มยังสามารถใช้เป็นฐานโจมตีแบบกระจาย (Distributed Denial of Service: DDoS) เพื่อถล่มระบบเป้าหมายได้อีกด้วย

ตัวอย่างเหตุการณ์จริงที่สร้างความเสียหายอย่างกว้างขวาง เช่น **Conficker (2008)** ซึ่งใช้ช่องโหว่ในระบบ Windows เพื่อแพร่กระจายผ่านเครือข่ายภายในองค์กร ทำให้เครื่องหลายล้านเครื่องทั่วโลกติดเชื่อ และ **WannaCry (2017)** แรนซัมแวร์ที่ใช้กลไกเวิร์มในการแพร่เชื้อผ่านช่องโหว่ SMBv1 ส่งผลให้หน่วยงานรัฐและองค์กรขนาดใหญ่ในกว่า 150 ประเทศหยุดชะงักการดำเนินงาน

แนวทางป้องกันเวิร์ม ที่สำคัญคือการรักษาความปลอดภัยของระบบให้ทันสมัยอยู่เสมอ โดยการอัปเดตแพตช์ (Patch) ระบบปฏิบัติการและซอฟต์แวร์เพื่อปิดช่องโหว่ที่อาจถูกเวิร์มใช้โจมตี ควรปิดพอร์ตเครือข่ายที่ไม่จำเป็นและใช้ไฟร์วอลล์เพื่อควบคุมการเชื่อมต่อ นอกจากนี้ การตรวจสอบทราฟฟิกในเครือข่ายด้วยระบบ IDS/IPS และการใช้ Endpoint

Detection & Response (EDR) ยังช่วยตรวจจับพฤติกรรมการแพร่กระจายผิดปกติได้อย่างมีประสิทธิภาพ

💡 **สรุป:** เวิร์มเป็นมัลแวร์ที่สามารถแพร่กระจายได้ด้วยตนเองผ่านเครือข่าย โดยไม่ต้องอาศัยผู้ใช้ จึงสามารถสร้างผลกระทบอย่างรุนแรงและรวดเร็ว การป้องกันที่มีประสิทธิภาพต้องอาศัยการอัปเดตระบบ ปิดพอร์ตที่ไม่จำเป็น และเฝ้าระวังพฤติกรรมในเครือข่ายอย่างต่อเนื่อง.

2.2.3. Trojan Horse (โทรจัน)

โทรจัน (Trojan Horse) เป็นมัลแวร์ที่ได้รับแรงบันดาลใจจาก “ม้าโทรจัน” ในตำนานสงครามกรุงทรอย ซึ่งภายนอกดูเหมือนไม่มีอันตราย แต่ภายในกลับซ่อนภัยร้ายไว้ เช่นเดียวกับชื่อของมัน โทรจันคอมพิวเตอร์คือ โปรแกรมที่ “ปลอมตัว” เป็นซอฟต์แวร์ปกติหรือแอปพลิเคชันที่ผู้ใช้เชื่อถือ เช่น โปรแกรมอัปเดต ระบบช่วยเหลือ หรือเครื่องมือเพิ่มประสิทธิภาพระบบ แต่เมื่อผู้ใช้ติดตั้งลงบนเครื่อง โทรจันจะเริ่มทำงานเบื้องหลัง โดยที่ผู้ใช้ไม่รู้ตัว และเปิดช่องทางให้ผู้โจมตีเข้าควบคุมระบบจากระยะไกลได้

ในเชิงเทคนิค กลไกการทำงานของโทรจัน มักเริ่มต้นจากการใช้เทคนิค “Social Engineering” เพื่อหลอกล่อให้ผู้ใช้ดาวน์โหลดและติดตั้ง โปรแกรมปลอม เช่น แอปพลิเคชันฟรีจากเว็บไซต์ที่ไม่น่าเชื่อถือ หรือไฟล์แนบจากอีเมลที่ปลอมเป็นเอกสารทางธุรกิจ เมื่อโทรจันถูกติดตั้ง มันจะสร้างช่องทางลับ (Backdoor) เพื่อให้ผู้โจมตีสามารถเข้าถึงระบบของเหยื่อได้โดยไม่ต้องผ่านการตรวจสอบสิทธิ์ บางครั้งโทรจันอาจส่งข้อมูลสำคัญ เช่น รหัสผ่าน หมายเลขบัตรเครดิต หรือไฟล์เอกสารภายในองค์กรกลับไปยังเซิร์ฟเวอร์ของผู้โจมตีโดยอัตโนมัติ

ผลกระทบของโทรจัน มีตั้งแต่การขโมยข้อมูลส่วนบุคคลและข้อมูลทางการเงิน ไปจนถึงการใช้เครื่องของเหยื่อเป็น “หุ่นยนต์” ในเครือข่าย Botnet เพื่อโจมตีเป้าหมายอื่น (เช่น การโจมตีแบบ DDoS) โทรจันบางประเภทสามารถดาวน์โหลดมัลแวร์อื่นเพิ่มเติม เช่น แรนซัมแวร์ หรือสปายแวร์ เพื่อขยายผลการโจมตีและสร้างความเสียหายที่รุนแรงยิ่งขึ้น

ตัวอย่างของโทรจันที่มีชื่อเสียง ได้แก่

- **Zeus Trojan** ซึ่งมุ่งขโมยข้อมูลการเงินจากผู้ใช้ธนาคารออนไลน์ โดยดักจับข้อมูลที่พิมพ์บนหน้าเว็บ (Form Grabbing) และส่งไปยังผู้โจมตี ทำให้เกิดความเสียหายต่อสถาบันการเงินหลายแห่ง
- **Emotet**, โทรจันที่เริ่มต้นจากการแพร่ผ่านอีเมลฟิชซิง และพัฒนาเป็นมัลแวร์แบบโมดูลาร์ (Modular Malware) ที่สามารถดาวน์โหลดมัลแวร์อื่นเพิ่มเติม เช่น TrickBot หรือ Ryuk ransomware

แนวทางป้องกันโทรจัน ควรเน้นทั้งเชิงเทคนิคและพฤติกรรมผู้ใช้ ในเชิงเทคนิค องค์กรควรใช้ **Application Whitelisting** เพื่อจำกัดการติดตั้งซอฟต์แวร์เฉพาะที่ได้รับอนุญาต รวมถึงใช้ระบบตรวจจับพฤติกรรม (Behavioral Analysis) และโซลูชัน EDR (Endpoint Detection & Response) เพื่อตรวจสอบกิจกรรมผิดปกติ นอกจากนี้ ในระดับผู้ใช้ ควรหลีกเลี่ยงการดาวน์โหลด โปรแกรมจากแหล่งที่ไม่เป็นทางการหรือเว็บไซต์ที่ไม่น่าเชื่อถือ ไม่เปิดไฟล์แนบหรือคลิกลิงก์ในอีเมลที่มาจากผู้ส่งที่ไม่รู้จัก และควรอัปเดตระบบและโปรแกรมให้เป็นเวอร์ชันล่าสุดอยู่เสมอ

💡 **สรุป:** โทรจันเป็นมัลแวร์ที่เน้น “หลอกล่อผู้ใช้ให้เปิดประตูให้ศัตรู” โดยภายนอกดูปลอดภัยแต่ซ่อนโค้ดอันตรายไว้ภายใน การป้องกันโทรจันจึงต้อง

อาศัยทั้งเทคโนโลยีตรวจจับสมัยใหม่และความระมัดระวังของผู้ใช้ เพื่อป้องกันไม่ให้ระบบกลายเป็นเหยื่อของการควบคุมจากระยะไกล.

2.2.4. Ransomware (แรนซัมแวร์)

แรนซัมแวร์ (Ransomware) เป็นมัลแวร์ที่มีวัตถุประสงค์หลักเพื่อ **เข้ารหัสข้อมูลของเหยื่อและเรียกค่าไถ่** เพื่อแลกกับการปลดล็อกไฟล์หรือระบบ แรนซัมแวร์จัดเป็นภัยคุกคามที่รุนแรงที่สุดรูปแบบหนึ่งในยุคปัจจุบัน เพราะสามารถทำให้ทั้งองค์กรหยุดชะงัก การดำเนินงาน สูญเสียข้อมูลสำคัญ และส่งผลกระทบต่อความเชื่อมั่นของลูกค้าหรือผู้ใช้บริการ

โดยทั่วไป กระบวนการทำงานของแรนซัมแวร์ มักเริ่มต้นจากการเข้าสู่ระบบผ่านอีเมลฟิชชิง (Phishing Email) ที่แนบไฟล์อันตรายหรือมีลิงก์ให้ดาวน์โหลดมัลแวร์ อีกช่องทางหนึ่งคือการใช้ช่องโหว่ (Vulnerability) ของระบบหรือบริการบนเครือข่าย เช่น โปรโตคอล SMB หรือ Remote Desktop (RDP) เมื่อมัลแวร์เข้าสู่ระบบได้แล้ว จะเริ่มสแกนหาไฟล์ที่สำคัญ เช่น เอกสาร รูปภาพ หรือฐานข้อมูล จากนั้นทำการ **เข้ารหัส (Encrypt)** ไฟล์เหล่านั้นด้วยคีย์เข้ารหัสเฉพาะ (Unique Encryption Key) ซึ่งมีเพียงผู้โจมตีเท่านั้นที่ถือคีย์ถอดรหัส (Decryption Key) อยู่

หลังจากเข้ารหัสข้อมูล แรนซัมแวร์จะ **แสดงข้อความเรียกค่าไถ่ (Ransom Note)** บนหน้าจอผู้ใช้ โดยมักอ้างว่าหากไม่ชำระเงินภายในเวลาที่กำหนด ข้อมูลจะถูกลบหรือเผยแพร่ต่อสาธารณะ การชำระเงินส่วนใหญ่จะถูกกำหนดให้จ่ายผ่านสกุลเงินดิจิทัล เช่น Bitcoin หรือ Monero เพื่อปกปิดตัวตนของผู้โจมตี แรนซัมแวร์รุ่นใหม่ ๆ ยังมีแนวโน้มใช้รูปแบบ “Double Extortion” หรือการขู่ว่าจะเปิดเผยข้อมูลของเหยื่อหากไม่ยอมจ่ายค่าไถ่ แม้จะมีการสำรองข้อมูลก็ตาม

ตัวอย่างเหตุการณ์ที่มีชื่อเสียง:

- **WannaCry (2017)** เป็นแรนซัมแวร์ที่ใช้ช่องโหว่ SMBv1 ของ Windows (EternalBlue Exploit) ในการแพร่กระจายตัวเองแบบเวอร์มิ ส่งผลกระทบต่อหน่วยงานและองค์กรกว่า 150 ประเทศทั่วโลก รวมถึงโรงพยาบาลและบริษัทขนส่งขนาดใหญ่
- **LockBit และ REvil** เป็นกลุ่มแรนซัมแวร์เชิงพาณิชย์ (Ransomware-as-a-Service: RaaS) ซึ่งให้บริการ “ขายหรือเช่า” โค้ดมัลแวร์ให้กับอาชญากรไซเบอร์รายอื่น โดยแบ่งส่วนแบ่งกำไรจากค่าไถ่ที่ได้รับ ทำให้การโจมตีแรนซัมแวร์กลายเป็นธุรกิจใต้ดินที่มีการจัดการอย่างเป็นระบบ

แนวทางป้องกันแรนซัมแวร์ ควรดำเนินการในหลายระดับ ได้แก่

- **การสำรองข้อมูลแบบออฟไลน์ (Offline Backup):** เก็บข้อมูลสำคัญไว้ในอุปกรณ์หรือระบบที่ไม่เชื่อมต่อกับเครือข่าย เพื่อให้สามารถกู้คืนได้โดยไม่ต้องจ่ายค่าไถ่
- **การตรวจจับเชิงพฤติกรรม (Behavioral Detection):** ใช้โซลูชัน EDR (Endpoint Detection & Response) หรือ XDR ที่สามารถตรวจจับกิจกรรมผิดปกติ เช่น การเข้ารหัสไฟล์จำนวนมากในระยะเวลาอันสั้น
- **การฝึกอบรมผู้ใช้ (User Awareness):** ให้งานระมัดระวังอีเมลต้องสงสัย ไม่เปิดไฟล์แนบหรือลิงก์จากผู้ส่งที่ไม่รู้จัก
- **การอัปเดตระบบและแพตช์ (Patch Management):** ปิดช่องโหว่ที่มัลแวร์อาจใช้โจมตี โดยเฉพาะบริการที่เปิดให้เข้าถึงผ่านอินเทอร์เน็ต เช่น RDP หรือ VPN

นอกจากนี้ องค์กรควรมี แผนตอบสนองเหตุการณ์ (Incident Response Plan) สำหรับกรณีถูกโจมตีแรนซัมแวร์ เพื่อดำเนินการจำกัดความเสียหาย (Containment) และกู้คืนระบบได้อย่างรวดเร็วโดยไม่ยอมจำนนต่อการเรียกค่าไถ่

💡 **สรุป:** แรนซัมแวร์เป็นภัยคุกคามที่ผสมผสานเทคนิคทางเทคโนโลยีเข้ากับการแบล็กเมลทางจิตวิทยา เป้าหมายไม่เพียงแค่การขโมยข้อมูล แต่คือการ “หยุดระบบและเรียกเงินคืน” การป้องกันที่มีประสิทธิภาพจึงต้องอาศัยการสำรองข้อมูล การตรวจจับพฤติกรรมผิดปกติ และการสร้างวัฒนธรรมความปลอดภัยทางไซเบอร์ในองค์กรอย่างต่อเนื่อง.

2.2.5. Spyware / Adware

Spyware และ **Adware** เป็นมัลแวร์ประเภทที่เกี่ยวข้องกับการละเมิดความเป็นส่วนตัวของผู้ใช้ แม้ทั้งสองประเภทจะไม่ทำลายระบบโดยตรงเหมือนไวรัสหรือแรนซัมแวร์ แต่กลับสร้างผลกระทบในระยะยาวต่อความปลอดภัยของข้อมูลส่วนบุคคล และมักถูกใช้เป็นเครื่องมือเสริมในการโจมตีทางไซเบอร์รูปแบบอื่น

Spyware (สปายแวร์) คือซอฟต์แวร์ที่ถูกออกแบบมาเพื่อ แอบเก็บข้อมูลของผู้ใช้โดยไม่ได้รับอนุญาต มักจะทำงานเบื้องหลังโดยที่ผู้ใช้ไม่รู้ตัว ข้อมูลที่ถูกเก็บอาจรวมถึงพฤติกรรมการใช้งานเว็บไซต์ รหัสผ่าน หมายเลขบัตรเครดิต หรือข้อมูลจากการกดแป้นพิมพ์ (Keylogging) เพื่อส่งกลับไปยังผู้โจมตี Spyware มักแฝงมากับซอฟต์แวร์ฟรีแวร์ โปรแกรมแชร์แวร์ หรือไฟล์แนบในอีเมลที่ผู้ใช้ติดตั้งเองโดยไม่ระมัดระวัง นอกจากนี้ บางเว็บไซต์อาจใช้สคริปต์หรือปลั๊กอินที่เป็นอันตรายในการดาวน์โหลดสปายแวร์เข้าสู่ระบบโดยอัตโนมัติผ่านเทคนิค “Drive-by Download”

ในขณะที่ **Adware** (แอดแวร์) เป็นโปรแกรมที่ แสดงโฆษณาโดยไม่ได้รับอนุญาตจากผู้ใช้ มักปรากฏในรูปแบบป๊อปอัพ (Pop-up), แบนเนอร์โฆษณา หรือการเปลี่ยนเส้นทางไปยังเว็บไซต์ที่ไม่พึงประสงค์ จุดประสงค์ของแอดแวร์ส่วนใหญ่คือเพื่อสร้างรายได้ให้กับผู้พัฒนา โดยการเพิ่มยอดการเข้าชมเว็บไซต์หรือคลิกโฆษณา อย่างไรก็ตาม แอดแวร์บางชนิดอาจมีความร้ายแรงมากขึ้น เช่น การดาวน์โหลดมัลแวร์อื่นเข้ามาในเครื่อง หรือใช้เป็นช่องทางในการติดตั้ง Spyware เพิ่มเติม

ผลกระทบจาก **Spyware** และ **Adware** มีหลายด้าน ทั้งการสูญเสียความเป็นส่วนตัว การถูกติดตามพฤติกรรมออนไลน์โดยไม่รู้ตัว และในบางกรณีอาจถูกใช้ในการขโมยข้อมูลที่สำคัญ เช่น รหัสผ่านบัญชีผู้ใช้หรือข้อมูลทางการเงิน ยิ่งไปกว่านั้น สปายแวร์และแอดแวร์อาจทำให้ระบบทำงานช้าลง สิ้นเปลืองทรัพยากรเครื่อง และกลายเป็นช่องทางให้มัลแวร์ประเภทอื่นเข้ามาติดตั้งเพิ่มเติม

ตัวอย่างของมัลแวร์ประเภทนี้ เช่น

- **CoolWebSearch** — แอดแวร์ที่เปลี่ยนหน้าเว็บค้นหาเริ่มต้น (Homepage Hijacking) และติดตามพฤติกรรมการท่องเว็บ
- **Gator** — ซอฟต์แวร์ที่แสดงโฆษณาเชิงพาณิชย์อย่างต่อเนื่องบนระบบ
- **Keylogger Variants** — โปรแกรมบันทึกการกดแป้นพิมพ์ที่ซับซ้อน ขโมยข้อมูลเข้าสู่ระบบต่าง ๆ เช่น บัญชีธนาคารออนไลน์

แนวทางป้องกัน Spyware / Adware

การป้องกันเริ่มจากการสร้างพฤติกรรมการใช้งานที่ปลอดภัย ผู้ใช้ควรหลีกเลี่ยงการติดตั้งซอฟต์แวร์จากแหล่งที่ไม่น่าเชื่อถือ โดยเฉพาะโปรแกรมฟรีแวร์หรือส่วนขยาย (Extension)

บนเบราว์เซอร์ที่ไม่ได้รับการตรวจสอบ ควรติดตั้งและใช้งานเครื่องมือ **Anti-Spyware** หรือระบบรักษาความปลอดภัยแบบบูรณาการ (Internet Security Suite) ที่สามารถตรวจจับและกำจัดสปายแวร์ได้แบบเรียลไทม์ รวมถึงอัปเดตซอฟต์แวร์และระบบปฏิบัติการอย่างสม่ำเสมอเพื่อปิดช่องโหว่ที่อาจถูกใช้ในการติดตั้งมัลแวร์ นอกจากนี้ การตรวจสอบสิทธิ์การเข้าถึง (Permissions) ของโปรแกรมต่าง ๆ ก่อนติดตั้งก็เป็นแนวทางที่ช่วยลดความเสี่ยงได้อย่างมีประสิทธิภาพ

💡 สรุป:

Spyware และ Adware อาจดูไม่อันตรายเท่ามัลแวร์ชนิดอื่น แต่ถือเป็นภัยคุกคามเงียบที่ละเมิดความเป็นส่วนตัวและเปิดช่องทางให้การโจมตีอื่นเกิดขึ้นได้ การป้องกันที่ดีจึงต้องเริ่มจาก “ความระมัดระวังของผู้ใช้” ควบคู่กับ “เครื่องมือป้องกันมัลแวร์ที่ทันสมัย” เพื่อรักษาความปลอดภัยของข้อมูลและระบบโดยรวม.

2.2.6. Rootkit

Rootkit เป็นมัลแวร์ที่ออกแบบมาโดยมีจุดประสงค์เพื่อ “ซ่อนตัว” (**Stealth**) และมอบคุณสมบัติการควบคุมระบบในระดับสูงสุดให้แก่ผู้โจมตี โดยทั่วไป Rootkit จะเข้ายึดสิทธิ์การทำงานระดับ **Kernel-level** ซึ่งเป็นระดับแกนหลักของระบบปฏิบัติการ ทำให้สามารถควบคุมกระบวนการ (Processes), ไฟล์, รีจิสทรี (Registry) หรือแม้แต่การสื่อสารเครือข่ายได้ โดยที่ผู้ใช้หรือ โปรแกรมป้องกันไวรัสไม่สามารถตรวจพบได้ง่าย ความอันตรายของ Rootkit อยู่ที่ความสามารถในการแอบแฝงตัวได้อย่างแนบเนียนในระบบเป็นระยะเวลานานโดยไม่ถูกตรวจจับ

ในเชิงเทคนิค Rootkit มักถูกติดตั้งหลังจากที่ผู้โจมตีได้สิทธิ์ระดับผู้ดูแลระบบ (Administrator / Root Access) ผ่านการโจมตีช่องโหว่หรือการขโมยรหัสผ่าน จากนั้นจะฝังตัวอยู่ในส่วนลึกของระบบ เช่น เคอร์เนล (Kernel), ไดรเวอร์ (Driver), หรือแม้แต่เฟิร์มแวร์ของฮาร์ดแวร์ เช่น BIOS / UEFI เพื่อปกปิดกิจกรรมที่เกิดขึ้น เช่น การเปิด Backdoor, การขโมยข้อมูล, หรือการโหลดมัลแวร์เพิ่มเติม

ลักษณะเฉพาะของ Rootkit คือความสามารถในการ ปิดบังการทำงานของตนเองจากระบบตรวจจับทั่วไป ไม่ว่าจะเป็น Antivirus, Task Manager หรือเครื่องมือตรวจสอบระบบอื่น ๆ Rootkit สามารถดักจับคำสั่งและแสดงข้อมูลปลอมให้กับผู้ใช้ เช่น ซ่อนไฟล์หรือกระบวนการบางอย่างไม่ให้ปรากฏในรายการ ทำให้ผู้ดูแลระบบเชื่อว่าระบบยังคงปลอดภัย ทั้งที่ในความเป็นจริงอาจถูกควบคุมจากระยะไกลแล้ว

ตัวอย่างเหตุการณ์ที่มีชื่อเสียงเกี่ยวกับ Rootkit ได้แก่:

- **Sony BMG Rootkit (2005):** เป็นหนึ่งในกรณีศึกษาคลาสสิกที่บริษัท Sony ได้แอบฝังซอฟต์แวร์จัดการสิทธิ์ดิจิทัล (Digital Rights Management — DRM) ลงในแผ่น CD เพลงโดยไม่แจ้งผู้ใช้ ซอฟต์แวร์ดังกล่าวทำงานในระดับระบบปฏิบัติการและซ่อนตัวเหมือน Rootkit ทำให้เกิดช่องโหว่ด้านความปลอดภัยและถูกวิพากษ์วิจารณ์อย่างหนัก
- **Necurs Rootkit:** เป็น Rootkit ที่มีบทบาทสำคัญในการสร้าง **Botnet ขนาดใหญ่** ระดับโลก โดยใช้ควบคุมเครื่องของเหยื่อให้ส่งสแปมหรือกระจายมัลแวร์อื่น เช่น Dridex หรือ Locky Ransomware

แนวทางป้องกัน Rootkit จำเป็นต้องเน้นทั้งการป้องกันเชิงรุกและการตรวจสอบความสมบูรณ์ของระบบอย่างต่อเนื่อง

- ใช้ระบบ **Secure Boot** เพื่อให้แน่ใจว่าเครื่องจะบูตเฉพาะซอฟต์แวร์ที่ได้รับการรับรองความถูกต้อง (Digitally Signed) เท่านั้น
- ใช้ **Signed Drivers** เพื่อป้องกันการโหลดไดรเวอร์อันตรายเข้าสู่ระบบ
- ตรวจสอบความสมบูรณ์ของไฟล์ระบบ, Kernel, และ Registry อย่างสม่ำเสมอด้วยเครื่องมือ เช่น Microsoft System File Checker (SFC), RootkitRevealer, หรือ GMER
- หากสงสัยว่าระบบติด Rootkit การแก้ไขอาจซับซ้อนถึงขั้นต้อง **ฟอร์แมตและติดตั้งระบบปฏิบัติการใหม่ทั้งหมด** เพื่อกำจัดมัลแวร์อย่างสิ้นเชิง

💡 สรุป:

Rootkit เป็นมัลแวร์ที่อันตรายอย่างยิ่งเพราะสามารถซ่อนตัวในระดับลึกของระบบและมอบคุณสิทธิ์สูงสุดแก่ผู้โจมตี ทำให้การตรวจจับและกำจัดเป็นเรื่องยาก การป้องกันจึงต้องอาศัยมาตรการตั้งแต่ระดับฮาร์ดแวร์ เช่น Secure Boot และการตรวจสอบความสมบูรณ์ของระบบอย่างต่อเนื่อง เพื่อป้องกันไม่ให้ “ภัยเงียบ” นี้ควบคุมเครื่องโดยไม่รู้ตัว.

2.2.7. Logic Bomb

Logic Bomb คือมัลแวร์ประเภทหนึ่งที่มีลักษณะเฉพาะคือ ถูกตั้งเงื่อนไขให้ทำงานเมื่อเกิดเหตุการณ์เฉพาะ (Conditional Execution) เช่น วันที่กำหนดไว้ล่วงหน้า การเข้าสู่ระบบของผู้ใช้ การลบหรือเพิ่มบัญชีผู้ใช้ใหม่ หรือการถึงกำหนดสิ้นสุดสัญญาการทำงาน มัลแวร์ประเภทนี้มักถูกแฝงอยู่ใน โปรแกรมหรือสคริปต์ที่ดูเหมือนปกติ แต่ภายในแฝงโค้ดอันตรายที่รอให้ “เงื่อนไข” ถูกกระตุ้นก่อนจะเริ่มทำงาน

ในเชิงเทคนิค **Logic Bomb** ไม่ได้แพร่กระจายเหมือนไวรัสหรือเวิร์ม แต่ถูกฝังไว้ในระบบโดยผู้ที่มีสิทธิ์เข้าถึง เช่น นักพัฒนาโปรแกรม (Developer) หรือเจ้าหน้าที่ระบบ (System Administrator) ที่ไม่พอใจองค์กร เมื่อถึงเวลาหรือเหตุการณ์ที่กำหนดไว้ มันจะเริ่มทำงานอัตโนมัติ เช่น ลบข้อมูลสำคัญในฐานข้อมูล ล้างไฟล์ระบบ ปิดการทำงานของบริการ หรือแสดงข้อความบางอย่างบนหน้าจอ การโจมตีแบบนี้มักเกิดขึ้นอย่างเฉียบพลันและสร้างความเสียหายสูง เพราะมักมาจากบุคคลภายในที่มีความเข้าใจเชิงเทคนิคของระบบเป็นอย่างดี

ตัวอย่างเหตุการณ์จริงที่มีชื่อเสียง เช่น

- **Time Bomb Malware** ซึ่งถูกตั้งเวลาให้ทำงานในวันหรือเวลาที่ระบุไว้ เช่น มัลแวร์บางชนิดที่ถูกโปรแกรมให้ลบข้อมูลหรือเข้ารหัสไฟล์ในวันที่ตรงกับ “วันครบรอบ” ของการเลิกจ้างพนักงาน หรือวันสำคัญขององค์กร
- **CIA Logic Bomb Case** ซึ่งเป็นกรณีเจ้าหน้าที่ IT ของหน่วยงานรัฐบาลในสหรัฐอเมริกาถูกจับได้ว่าฝังโค้ดลับในระบบเครือข่าย เพื่อให้เมื่อใดก็ตามที่เขาถูกไล่ออกจากงาน ระบบจะลบข้อมูลและปิดการทำงานของเครื่องแม่ข่ายโดยอัตโนมัติ

แนวทางป้องกัน **Logic Bomb** จำเป็นต้องเน้นไปที่ การบริหารจัดการสิทธิ์และการตรวจสอบการเปลี่ยนแปลงภายในระบบ (Change Management) มากกว่าการพึ่งพาเครื่องมือป้องกันไวรัสทั่วไป

- ควรใช้ระบบ **Version Control** และ **Code Review** เพื่อให้มีการตรวจสอบโค้ดจากหลายฝ่ายก่อนนำขึ้นใช้งานจริง
- ใช้ระบบ **Change Management System** เพื่อบันทึกและอนุมัติการแก้ไขซอร์สโค้ดหรือสคริปต์ภายในองค์กรทุกครั้ง

- จำกัดสิทธิ์การเข้าถึง (Access Control) เฉพาะบุคคลที่จำเป็นต่อการพัฒนาและดูแลระบบเท่านั้น โดยเฉพาะในส่วนของโค้ดที่สำคัญ
- จัดให้มีการตรวจสอบและบันทึกกิจกรรม (Audit Log) ของผู้พัฒนาหรือผู้ดูแลระบบ เพื่อให้สามารถสืบค้นย้อนหลังได้ในกรณีที่เกิดเหตุผิดปกติ

💡 สรุป:

Logic Bomb เป็นมัลแวร์ที่ “เงียบและรอเวลา” ในการสร้างความเสียหาย มักถูกฝังโดยบุคคลภายในองค์กรที่มีสิทธิ์เข้าถึงระบบ การป้องกันจึงต้องอาศัยการบริหารจัดการสิทธิ์ การตรวจสอบโค้ด และกระบวนการควบคุมการเปลี่ยนแปลงอย่างเข้มงวด เพื่อป้องกันไม่ให้โค้ดอันตรายถูกฝังในระบบโดยไม่รู้ตัว.

2.2.8. Botnet / Zombie

Botnet คือเครือข่ายของคอมพิวเตอร์หรืออุปกรณ์ดิจิทัลที่ถูกมัลแวร์ควบคุมจากระยะไกลโดยผู้โจมตี โดยเครื่องที่ติดมัลแวร์และอยู่ภายใต้การควบคุมจะถูกเรียกว่า **Zombie** (ซอมบี้) ซึ่งหมายถึงอุปกรณ์ที่ยังทำงานตามปกติแต่ไม่มีการควบคุมโดยเจ้าของอีกต่อไป ผู้โจมตีสามารถใช้คำสั่งจากส่วนกลางเพื่อสั่งให้เครื่องเหล่านี้ทำงานประสานกัน เช่น การโจมตีแบบ DDoS (Distributed Denial of Service), การส่งสแปมอีเมล, การขูดเหรียญดิจิทัล หรือแม้แต่การแพร่กระจายมัลแวร์เพิ่มเติม

ในเชิงเทคนิค กลไกการทำงานของ **Botnet** เริ่มต้นจากการที่มัลแวร์เข้าไปติดตั้งบนเครื่องของเหยื่อ ซึ่งอาจเกิดจากการเปิดไฟล์แนบอีเมลอันตราย ดาวน์โหลดซอฟต์แวร์เถื่อน หรืออุปกรณ์ IoT ที่ไม่ได้รับการป้องกัน เมื่อเครื่องติดมัลแวร์แล้ว จะเชื่อมต่อกับ **Command and Control Server (C2 Server)** ซึ่งเป็นศูนย์กลางการสั่งการของผู้โจมตี การติดต่อสื่อสารนี้อาจใช้โปรโตคอลต่าง ๆ เช่น HTTP, IRC, หรือแม้แต่การสื่อสารแบบเข้ารหัสผ่าน Tor เพื่อหลบเลี่ยงการตรวจจับ หลังจากเชื่อมต่อสำเร็จ เครื่องเหยื่อจะรอรับคำสั่งจาก C2 และสามารถถูกสั่งให้ทำงานพร้อมกันหลายหมื่นหรือหลายล้านเครื่องได้ในเวลาเดียวกัน

ผลกระทบของ Botnet มีความร้ายแรงทั้งในระดับบุคคลและองค์กร เพราะ Botnet สามารถใช้ทรัพยากรของเหยื่อโดยไม่รู้ตัว เช่น การใช้พลังประมวลผล CPU หรือแบนด์วิดท์เครือข่าย นอกจากนี้การโจมตีแบบ DDoS ที่เกิดจาก Botnet ขนาดใหญ่สามารถทำให้เว็บไซต์หรือบริการออนไลน์หยุดชะงักได้ในวงกว้าง ตัวอย่างเช่น การโจมตีที่มีปริมาณทราฟฟิกหลายร้อยกิกะบิตต่อวินาทีจนระบบเป้าหมายไม่สามารถให้บริการได้

ตัวอย่างเหตุการณ์ที่สำคัญ:

- **Mirai Botnet (2016):** เป็นกรณีศึกษาคลาสสิกของ Botnet ที่ใช้ประโยชน์จากอุปกรณ์ Internet of Things (IoT) เช่น กล้องวงจรปิดและเราเตอร์ที่ใช้รหัสผ่านเริ่มต้น (default credentials) เพื่อเข้าควบคุมและรวมเป็นเครือข่าย Botnet ขนาดใหญ่ การโจมตีของ Mirai ส่งผลให้เว็บไซต์ขนาดใหญ่ระดับโลก เช่น Twitter, Netflix และ GitHub ล่มชั่วคราว
- **Storm Worm** และ **Emotet** ก็เป็นตัวอย่างของมัลแวร์ที่สร้างโครงสร้าง Botnet เพื่อส่งสแปมและดาวน์โหลดมัลแวร์อื่นต่อไปยังเครื่องเหยื่อจำนวนมาก

แนวทางป้องกัน Botnet จำเป็นต้องเน้นทั้งในระดับผู้ใช้และระดับองค์กร

- ในระดับผู้ใช้ ควรติดตั้งโปรแกรมป้องกันไวรัสหรือระบบ **EDR (Endpoint Detection & Response)** เพื่อป้องกันไม่ให้มัลแวร์เข้ามาติดตั้งและเชื่อมต่อกับ

เซิร์ฟเวอร์ควบคุม

- ในระดับเครือข่าย ควรใช้ **ไฟร์วอลล์ (Firewall)** และ **ระบบตรวจจับ/ป้องกันการบุกรุก (IDS/IPS)** เพื่อเฝ้าระวังการติดต่อกับ โดเมนหรือ IP ที่เกี่ยวข้องกับ C2 Servers
- สำหรับอุปกรณ์ IoT ควรอัปเดตเฟิร์มแวร์อย่างสม่ำเสมอ เปลี่ยนรหัสผ่านเริ่มต้น และปิดบริการที่ไม่จำเป็นเพื่อป้องกันการเข้าควบคุมจากภายนอก
- นอกจากนี้ องค์กรควรมีระบบ **Threat Intelligence** เพื่อตรวจสอบ โดเมนหรือที่อยู่ IP ที่มีพฤติกรรมต้องสงสัย และบล็อกการเชื่อมต่อก่อนที่จะเกิดความเสียหาย

💡 สรุป:

Botnet คือการรวมพลังของอุปกรณ์ที่ถูกยึดครองเพื่อสร้าง “กองทัพมัลแวร์” ภายใต้การควบคุมของผู้โจมตี ความอันตรายไม่ได้อยู่ที่การติดมัลแวร์เพียงเครื่องเดียว แต่คือ “การทำงานร่วมกันของหลายหมื่นเครื่องในเวลาเดียวกัน” การป้องกันที่มีประสิทธิภาพจึงต้องอาศัยการตรวจจับเชิงรุก การควบคุมทราฟฟิกเครือข่าย และการบริหารจัดการอุปกรณ์ IoT อย่างปลอดภัย.

2.2.9. Fileless Malware

Fileless Malware คือมัลแวร์ยุคใหม่ที่ออกแบบมาเพื่อหลีกเลี่ยงการตรวจจับแบบดั้งเดิม โดย **ไม่สร้างไฟล์ชั่วคราวลงบนดิสก์** แต่รันคำสั่งหรือ โค้ดทั้งหมดในหน่วยความจำ (RAM) แทน เทคนิคนี้มักอาศัยเครื่องมือและเฟิร์มแวร์ที่มีอยู่แล้วในระบบปฏิบัติการ (so-called “living-off-the-land”) เช่น PowerShell, Windows Management Instrumentation (WMI), หรือคอมโพเนนต์ระบบอื่น ๆ ทำให้โปรแกรมสแกนแบบพึ่งพาลายเซ็นหรือการค้นหาไฟล์ไม่สามารถจับพฤติกรรมได้ง่าย ๆ และเพิ่มความยากในการวิเคราะห์หลังเกิดเหตุ

ในด้าน กลไกการทำงาน มัลแวร์ประเภทนี้มักเริ่มจากการได้รับคอมมานด์หรือสคริปต์ผ่านเครือข่าย (เช่น จากลิงก์ในอีเมลฟิชชิ่งหรือจากเว็บที่ถูกโจมตี) โค้ดจะถูกโหลดเข้ามาและดำเนินการทั้งหมดในหน่วยความจำโดยไม่เขียนไฟล์ลงดิสก์บางกรณีใช้เทคนิคเช่น reflective DLL injection หรือการฝังสคริปต์ในกระบวนการที่ถูกต้องตามระบบเพื่อหลบเลี่ยงการตรวจพบ เมื่องานสิ้นสุดหรือเครื่องรีบูต โค้ดที่อยู่ในหน่วยความจำจะหายไป แต่มัลแวร์มักมีกลไกให้กลับมาทำงานอีกครั้ง เช่น การตั้งค่างาน (scheduled task), การใช้ WMI subscription, หรือการฝังโค้ดไว้ใน registry/เฟิร์มแวร์เพื่อยิงสคริปต์ซ้ำ ทำให้การกำจัดอาจจำเป็นต้องตรวจสอบทั้งพฤติกรรมหน่วยความจำและจุดยึดถาวรเหล่านี้ด้วย

ตัวอย่างเชิงปฏิบัติ ที่มักถูกอ้างอิง ได้แก่เครื่องมือหรือเฟรมเวิร์กที่ผู้โจมตีใช้เป็น payload แบบ fileless เช่น *PowerShell Empire* และ *Cobalt Strike* (เมื่อใช้เป็น fileless payload) ซึ่งทั้งสองสามารถรันคำสั่งในหน่วยความจำและประสานงานกับเซิร์ฟเวอร์ควบคุมโดยไม่ทิ้งไฟล์ที่ชัดเจนบนดิสก์ ทำให้เป็นเครื่องมือยอดนิยมของกลุ่มผู้โจมตีมืออาชีพ

แนวทางป้องกันและลดความเสี่ยง ต่อ Fileless Malware ควรรวมทั้งมาตรการด้านการกำหนดนโยบาย การตั้งค่าควบคุม และการตรวจจับเชิงพฤติกรรม เช่น

- จำกัดการใช้เครื่องมือสคริปต์ระดับระบบ (PowerShell, WMI) โดยนโยบาย: เปิดใช้งาน Execution Policy ที่เข้มงวด และปิดเฟิร์มแวร์ที่ไม่จำเป็นใน production environment
- เปิดใช้เฟิร์มแวร์ความปลอดภัยในตัวระบบ เช่น AMSI (Antimalware Scan Interface) กับ PowerShell, และบังคับใช้การตรวจสอบดิจิทัลของสคริปต์

- ใช้ **Application Control / Whitelisting** (เช่น AppLocker, Defender Application Control) เพื่อป้องกันการรันโค้ดจากแหล่งที่ไม่ได้รับอนุญาต
- ติดตั้งและใช้งาน โซลูชัน **EDR/XDR** ที่สามารถตรวจจับพฤติกรรมในหน่วยความจำ (memory-based indicators) และทำ threat hunting เพื่อค้นหากิจกรรมที่ผิดปกติ เช่น การฉีดโค้ดเข้า process ที่น่าเชื่อถือหรือการเชื่อมต่อ C2 แบบแปลก ๆ
- เก็บและวิเคราะห์ล็อกเชิงกิจกรรม (process creation, script execution, network connections) ใน SIEM เพื่อให้สามารถสืบย้อนและจุดเชื่อมโยงการโจมตีได้
- ปรับปรุงแพตช์และลดพื้นผิวการโจมตี (disable unused services, least-privilege) เพื่อลดโอกาสที่ผู้โจมตีจะได้สิทธิ์พอที่จะรันสคริปต์ในหน่วยความจำ

Key takeaway: Fileless malware ใช้ประโยชน์จากความสามารถปกติของระบบเพื่อซ่อนตัวและรันในหน่วยความจำ วิธีป้องกันต้องเน้นการจำกัดพีเจอรี่ที่ใช้เป็นช่องทาง การบังคับใช้นโยบายการรันสคริปต์ รวมถึงการใช้ EDR/การตรวจจับเชิงพฤติกรรมเพื่อเห็นพฤติกรรมที่ไม่ขึ้นอยู่กับไฟล์บนดิสก์เท่านั้น.

2.2.10. ตารางสรุปเปรียบเทียบประเภทของมัลแวร์

ประเภทมัลแวร์	วิธีแพร่กระจาย	ผลกระทบหลัก	ตัวอย่างจริง	แนวทางป้องกันเบื้องต้น
Virus	ไฟล์แนบ / โปรแกรม	ทำลายไฟล์	ILOVEYOU, Melissa	Antivirus, ไม่เปิดไฟล์แนบ
Worm	ช่องโหว่เครือข่าย	ทำให้ระบบล่ม	Conficker, WannaCry	อัปเดตแพตช์, ปิดพอร์ต
Trojan	ดาวน์โหลดโปรแกรมปลอม	เปิดช่องหลังบ้าน	Zeus, Emotet	Whitelisting, EDR
Ransomware	Phishing / Exploit	เข้ารหัสข้อมูล	WannaCry, LockBit	สำรองข้อมูล, EDR
Spyware/Adware	ฟรีแวร์ / เว็บไซต์	ล้วงข้อมูล	Keylogger, CoolWebSearch	Anti-spyware, Awareness
Rootkit	สิทธิ์ผู้ดูแลระบบ	ซ่อนมัลแวร์	Necurs, Sony BMG	Secure Boot, Kernel Scan
Logic Bomb	เงื่อนไขในโค้ด	ลบหรือทำลายข้อมูล	Time Bomb	Code Review, Policy Control
Botnet	การติดเชื้อจำนวนมาก	ใช้โจมตี DDoS	Mirai, Storm Worm	IDS/IPS, Network Segmentation
Fileless	Memory Injection	หลบการตรวจจับ	Cobalt Strike	จำกัด Script, EDR

2.2.11. สรุปแนวคิดสำคัญ (Key Takeaways)

- มัลแวร์แต่ละประเภทมี กลไกการโจมตีและเป้าหมายต่างกัน แต่ล้วนมีผลกระทบต่อความมั่นคงของระบบสารสนเทศ

- การป้องกันมัลแวร์ต้องอาศัยแนวคิด **Defense in Depth** — การใช้หลายชั้นของการป้องกัน เช่น Antivirus, IDS/IPS, Patch Management และการอบรมผู้ใช้
- แนวทางสมัยใหม่เน้น **Behavioral Detection** และ **Threat Intelligence** เพื่อจับพฤติกรรมผิดปกติแทนการพึ่งพาลายเซ็น (Signature) เพียงอย่างเดียว

เยี่ยมมากครับ 🎯

ด้านล่างนี้คือ เนื้อหาตำราเรียนฉบับสมบูรณ์

สำหรับหัวข้อ **Chapter 2 — Malware**

ตอนที่ **2.3 Malware: Delivery, Detection & Response**

เขียนในรูปแบบ ตำราเรียนทางวิชาการสำหรับนักศึกษาวิทยาการคอมพิวเตอร์ / ไซเบอร์
ความปลอดภัย

พร้อมตัวอย่างจริง ตาราง Checklist และ Playbook ครบตามโครงสร้างที่กำหนด

2.3 Malware: Delivery, Detection & Response

2.3.1. Malware Delivery Vectors

ช่องทางการแพร่เชื้อของมัลแวร์ (Malware Delivery Vectors) คือกลไกหรือเส้นทางที่ผู้โจมตีใช้ในการส่งโค้ดอันตรายเข้าสู่ระบบเป้าหมาย การเข้าใจช่องทางเหล่านี้ช่วยให้นักรักษาความปลอดภัยสามารถวางมาตรการป้องกันที่มีประสิทธิภาพและลดความเสี่ยงในการติดเชืได้อย่างเป็นระบบ

Phishing

Phishing เป็นช่องทางที่พบบ่อยที่สุดในการแพร่มัลแวร์ ผู้โจมตีส่งอีเมลหรือข้อความที่ดูน่าเชื่อถือพร้อมไฟล์แนบหรือ URL ที่มีโค้ดอันตราย เมื่อเหยื่อคลิกเปิดเอกสารหรือเข้าสู่ลิงก์ดังกล่าว มัลแวร์จะถูกดาวน์โหลดหรือติดตั้งทันที ตัวอย่างเช่น **Emotet** ที่เริ่มจากอีเมลแนบไฟล์ Word พร้อมมาโครซ่อนโค้ดดาวน์โหลดมัลแวร์อื่น

แนวทางป้องกัน: ฝึกอบรมผู้ใช้ให้รู้เท่าทันฟิชซิง, ใช้ระบบอีเมลเกตเวย์ (Email Security Gateway) ที่มีการสแกนไฟล์แนบ, และบังคับใช้การปิดมาโครโดยค่าเริ่มต้นใน Office Applications

Drive-by Download

คือการติดมัลแวร์จากเว็บไซต์ที่ถูกแฮ็กหรือมีสคริปต์อันตราย โดยไม่จำเป็นต้องคลิกใด ๆ เช่น มัลแวร์จะใช้ช่องโหว่ของเบราว์เซอร์หรือปลั๊กอิน (เช่น Flash, Java) เพื่อรันโค้ดโจมตีโดยอัตโนมัติ

แนวทางป้องกัน: อัปเดตเบราว์เซอร์และปลั๊กอินให้เป็นเวอร์ชันล่าสุด, ใช้ Web Filtering / Content Security Policy, และติดตั้งปลั๊กอินป้องกันสคริปต์

USB / Removable Media

อุปกรณ์พกพา เช่น Flash Drive มักถูกใช้เป็นพาหะในการนำมัลแวร์เข้าสู่ระบบ โดยเฉพาะในสภาพแวดล้อมที่ไม่ได้เชื่อมต่ออินเทอร์เน็ต เช่น เครือข่ายองค์กรภาครัฐ

แนวทางป้องกัน: ปิดระบบ AutoRun, ใช้ Endpoint Protection ที่ควบคุมการใช้อุปกรณ์ภายนอก, และเข้ารหัสข้อมูลใน USB

Exploit / Public-Facing Services

ผู้โจมตีมักค้นหาบริการที่เปิดให้เข้าถึงผ่านอินเทอร์เน็ต เช่น RDP, SMB, FTP หรือ Web Server แล้วใช้ช่องโหว่เพื่อเข้ายึกระบบ ตัวอย่างเช่นการโจมตี **EternalBlue** ที่ทำให้ WannaCry แพร่ระบาดทั่วโลก

แนวทางป้องกัน: ปิดพอร์ตที่ไม่จำเป็น, ใช้ VPN สำหรับการเข้าถึงระยะไกล, และอัปเดตแพตช์อย่างสม่ำเสมอ

Supply-Chain Attack

การโจมตีผ่านซอฟต์แวร์หรืออัปเดตจากซัพพลายเออร์ เช่น กรณี **SolarWinds (2020)** ที่ผู้โจมตีฝังมัลแวร์ในตัวอัปเดตของซอฟต์แวร์ที่องค์กรทั่วโลกใช้งาน

แนวทางป้องกัน: ตรวจสอบความถูกต้องของซอฟต์แวร์ที่ติดตั้ง (Code Signing), ใช้ระบบ Software Bill of Materials (SBOM), และทดสอบอัปเดตใน sandbox ก่อนใช้งานจริง

Quick Prevention Checklist

1. เปิดใช้ระบบ Patch Management และอัปเดตอัตโนมัติ
2. ใช้ MFA สำหรับบัญชีผู้ดูแลและการเข้าถึงระยะไกล
3. ปิด AutoRun และจำกัดการใช้ USB
4. เปิดใช้งาน Email Filtering + Sandboxing
5. ติดตั้ง Firewall / IDS/IPS ที่ตรวจจับทราฟฟิกผิดปกติ
6. ตรวจสอบแหล่งซอฟต์แวร์ก่อนติดตั้ง
7. ฝึกอบรม Phishing Awareness อย่างต่อเนื่อง

2.3.2. Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ “สัญญาณบ่งชี้ว่าระบบอาจถูกบุกรุก” ใช้ในการตรวจจับ วิเคราะห์ และตอบสนองเหตุการณ์ทางไซเบอร์อย่างมีหลักฐานทางเทคนิค IoCs สามารถรวบรวมจากระบบ Endpoint, Logs, Network Traffic หรือ Threat Intelligence Feed

ประเภทของ IoCs และตัวอย่างจำลอง

- **File-based:** ชื่อไฟล์หรือ Hash เช่น
 - invoice_update.exe ,
SHA256= e99a18c428cb38d5f260853678922e03a...
- **Registry-based:** Key หรือ Value ที่มัลแวร์ใช้ในการ persistence
 - HKCU\Software\Microsoft\Windows\CurrentVersion\Run\sysupdate
= C:\Temp\evil.ps1
- **Process/Service anomalies:** Process ที่ไม่ตรงกับพฤติกรรมปกติ เช่น powershell.exe รันโดย svchost.exe
- **Network Indicators:** IP / Domain ที่ใช้เป็น Command & Control เช่น c2.evilexample[.]net:8443

- **Behavioral Indicators:** การเข้ารหัสไฟล์เป็นจำนวนมาก, การสร้าง Scheduled Tasks ผิดปกติ, หรือการเชื่อมต่อช่วงเวลานอกเวลาทำงาน

การจัดเก็บและแชร์ IoCs

องค์กรควรใช้รูปแบบมาตรฐาน เช่น **STIX/TAXII** ในการแลกเปลี่ยนข้อมูล และเชื่อมต่อกับระบบ **SIEM (Security Information and Event Management)** เพื่อแจ้งเตือนอัตโนมัติ IoCs ที่ดีควรประกอบด้วย timestamp, confidence score และแหล่งที่มา (source of intelligence)

2.33. Detection Techniques

การตรวจจับมัลแวร์มีหลายแนวทาง โดยทั่วไปแบ่งเป็น 4 เทคนิคหลักที่มักใช้ร่วมกันเพื่อเพิ่มความแม่นยำ

Signature-based Detection

ใช้ลายเซ็นหรือ hash ของมัลแวร์ที่รู้จัก เปรียบเทียบกับฐานข้อมูลใน Antivirus เช่น ClamAV หรือ YARA Rules
ข้อดี: ตรวจจับมัลแวร์ที่รู้จักได้แม่นยำ
ข้อเสีย: ไม่สามารถจับมัลแวร์ใหม่หรือที่เปลี่ยนโค้ด

Heuristic / Static Analysis

วิเคราะห์ไฟล์โดยไม่ต้องรันจริง เช่น ตรวจสอบคำสั่งต้องสงสัย หรือโค้ดที่ถูกเข้ารหัส
ข้อดี: ตรวจจับมัลแวร์ใหม่หรือสายพันธุ์ที่ใกล้เคียง
ข้อเสีย: มีโอกาสเกิด False Positive สูง

Behavioral / Anomaly Detection

สังเกตพฤติกรรมของโปรเซสและระบบ เช่น การสร้างไฟล์จำนวนมาก การเชื่อมต่อ C2 หรือการแก้ไข Registry
ข้อดี: ตรวจจับมัลแวร์แบบ Fileless และ Zero-day
ข้อเสีย: ต้องใช้เครื่องมือและทรัพยากรสูง เช่น EDR/XDR

Memory Analysis

ตรวจสอบหน่วยความจำเพื่อหาการฝังโค้ด (Code Injection) หรือ Shellcode ที่รันอยู่ เช่น ใช้ **Volatility** หรือ **Rekall**
ข้อดี: ตรวจจับ Rootkit หรือ Fileless Malware
ข้อเสีย: ต้องมีความชำนาญด้าน Forensics

Technique	Detects	Strengths	Weaknesses	Tools
Signature	Known malware	รวดเร็ว, แม่นยำ	ไม่จับมัลแวร์ใหม่	ClamAV, YARA
Heuristic	Similar variants	พบมัลแวร์ใกล้เคียง	False Positive	Static analyzers

Technique	Detects	Strengths	Weaknesses	Tools
Behavioral	Anomalous actions	เหมาะกับ Zero-day	ต้องปรับแต่ง	EDR/XDR
Memory	In-memory threats	ตรวจจับ rootkit	ต้องมีทักษะ	Volatility, Rekall

2.3.4. Incident Response: Contain, Eradicate, Recover

การตอบสนองเหตุการณ์ (Incident Response – IR) คือการจัดการมัลแวร์อย่างมีระบบ ประกอบด้วย 3 ขั้นตอนหลัก

Contain (จำกัดการแพร่กระจาย) → Eradicate (กำจัดภัยคุกคาม) → Recover (กู้คืนระบบ)

Playbook A: Ransomware Infection

1. ตรวจจับเหตุการณ์ผ่าน EDR หรือ SIEM
2. แยกเครื่องที่ติดเชื้อออกจากเครือข่ายทันที
3. บันทึกหลักฐาน: memory dump, logs, process tree
4. ระบุ strain ของ ransomware (เช่น LockBit, WannaCry)
5. ลบหรือ reimagine ระบบที่ได้รับผลกระทบ
6. กู้คืนข้อมูลจาก offline backup ที่ทดสอบแล้ว
7. เปลี่ยนรหัสผ่านทุกบัญชี และตรวจสอบช่องโหว่ที่ใช้โจมตี

Playbook B: C2-connected Botnet

1. ตรวจพบการเชื่อมต่อไปยัง C2 ผ่าน IDS/Firewall
2. บล็อก IP/Domain ทันทีที่ perimeter firewall
3. แยกเครื่องที่ติดเชื้อจากเครือข่าย
4. เก็บ memory image, process list และ network capture
5. ลบมัลแวร์และ scheduled tasks
6. ตรวจสอบ lateral movement และ reset credentials
7. ตรวจสอบ logs อย่างต่อเนื่องหลังฟื้นฟู

ข้อควรระวังด้าน Forensics: ห้ามรีบูตหรือ format เครื่องก่อนเก็บ volatile evidence (หน่วยความจำ, connection state, logs)

2.3.5. Removal & Remediation Best Practices

การลบและฟื้นฟูระบบต้องทำอย่างระมัดระวังเพื่อไม่ให้มัลแวร์กลับมาอีก

ขั้นตอนมาตรฐาน:

1. Isolate เครื่องที่ติดเชื้อและบัญชีผู้ใช้ที่เกี่ยวข้อง
2. เก็บหลักฐาน (memory/disk image) เพื่อวิเคราะห์
3. วิเคราะห์ Root Cause ของการติดมัลแวร์
4. เลือกวิธีการลบ:

- **Targeted Removal** หากมัลแวร์ไม่ฝังลึก
- **Reimage** หากพบ Rootkit หรือ persistence

5. เปลี่ยนรหัสผ่านและรีเซ็ตคีย์ทั้งหมด
6. ตรวจสอบความสมบูรณ์ของไฟล์และ log หลังการลบ
7. ตรวจสอบการกู้คืนข้อมูลด้วย checksum

Checklist สำหรับการคืนระบบสู่ Production:

- ☒ สำรองข้อมูลก่อน restore
- ☒ ติดตั้ง patch ล่าสุด
- ☒ ตรวจสอบว่าไม่มี process ต้องสงสัย
- ☒ เปลี่ยน credentials ของ service accounts
- ☒ เปิดการตรวจจับแบบ real-time monitoring
- ☒ ทำ vulnerability scan ซ้ำก่อนเปิดบริการ

2.3.6. Preventive Controls & Hardening

การป้องกันล่วงหน้าเป็นวิธีที่คุ้มค่าที่สุดในการลดโอกาสการติดมัลแวร์ โดยใช้หลักการ **Defense in Depth**

มาตรการสำคัญ:

- **Patch Management:** อัปเดตระบบและซอฟต์แวร์ทุกสัปดาห์
- **MFA:** บังคับใช้หลายปัจจัยสำหรับการเข้าถึงระบบสำคัญ
- **Network Segmentation:** แยก VLAN สำหรับผู้ใช้/เซิร์ฟเวอร์สำคัญ
- **Least Privilege:** มอบสิทธิ์เท่าที่จำเป็น
- **Application Whitelisting:** อนุญาตเฉพาะโปรแกรมที่อนุมัติแล้ว
- **Immutable Backup:** สำรองข้อมูลแบบแก้ไขไม่ได้และแยกเก็บนอกเครือข่าย
- **Endpoint Protection (EDR):** ตรวจจับพฤติกรรมมัลแวร์เชิงลึก
- **User Awareness:** ฝึกอบรมด้านความปลอดภัยไซเบอร์ทุกไตรมาส

Configuration Hints:

- ปิด RDP สำหรับเครื่องที่ต่ออินเทอร์เน็ต
- เปิดใช้ PowerShell ConstrainedLanguageMode
- ปิด SMBv1 และเปิด SMB Signing
- ใช้ Firewall ACL จำกัด outbound traffic

Top 10 Hardening Checklist

1. Patch ระบบอย่างสม่ำเสมอ
2. บังคับใช้ MFA สำหรับบัญชีผู้ดูแล
3. แบ่ง VLAN และจำกัดการเข้าถึง
4. ติดตั้ง EDR ทุกเครื่อง
5. เปิด Centralized Logging (SIEM)
6. ใช้ Application Whitelisting
7. สำรองข้อมูลออฟไลน์และทดสอบกู้คืน

8. จำกัดสิทธิ์ผู้ใช้ตามบทบาท
9. ฝึกอบรมพนักงานและจำลอง Phishing Test
10. ใช้ Threat Intelligence สำหรับการบล็อกโดเมนต้องสงสัย

Key Takeaways

1. ช่องทางการแพร่กระจายมีหลายแบบ — การรับรู้ช่วยให้ป้องกันได้ตรงจุด
2. IoCs เป็นหลักฐานสำคัญในการตรวจจับและสืบสวนเหตุการณ์
3. การตรวจจับที่ดีต้องผสมผสาน Signature, Behavioral และ Memory Analysis
4. การตอบสนองเหตุการณ์ต้องวางแผนและเก็บหลักฐานก่อนฟื้นฟูระบบ
5. การป้องกันเชิงรุกและ Hardening อย่างต่อเนื่องคือรากฐานของความมั่นคงปลอดภัยทางไซเบอร์